CSA6303- Threat Intelligence and Network Security

AT1: Application-Based Questions

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats |Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan

Total: 50

Student Name :VELUGU KIRAN BOJA RAJU **Register number: 192312353**

Code of Conduct:

I **_Velugu Kiran Boja Raju/192312353** *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:*V.Kiran**

AT1: Application-Based Questions

Q1.CIA Triad — Scenario Identification (5 marks)
An e-commerce site stays fully online during an incident, but customers notice product prices have been silently changed by an attacker who gained database write access. No downtime occurred. Which CIA Triad principle(s) are violated? Justify your answer

Q2. Risk Quantification — Annualized Loss Expectancy (10 marks)
A company's customer database is valued at $50,000. A breach would destroy/corrupt 40% of its value (Exposure Factor). Historical data shows this type of breach occurs about twice a year (Annualized Rate of Occurrence = 2). Calculate the Single Loss Expectancy (SLE) and the Annualized Loss Expectancy (ALE). Show all formulas used.

Q3. Brute-Force Attack Time Estimation (10 marks)
An 8-character password uses a 62-character set (a-z, A-Z, 0-9). An attacker's cracking rig tests 1 billion passwords per second. Calculate the size of the keyspace and the worst-case time required to exhaust it. Express your answer in hours.

Q4. Risk Prioritization Matrix (10 marks)
Given five threats rated on Likelihood (1-5) and Impact (1-5), compute the Risk Score (Likelihood x Impact) for each and rank them in order of patching/budget priority:
(a) Ransomware — L4, I5;
(b) Phishing — L5, I3;
(c) Insider data theft — L2, I5;
(d) DDoS — L3, I3;
(e) Unpatched server exploit — L4, I4.

Q5. Passive vs. Active Threat Classification (5 marks)
Classify each of the following as a passive or active threat, and state which CIA principle it primarily threatens:
(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.
(b) An attacker performing ARP spoofing to redirect traffic.
(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Q6. Threat Intelligence Lifecycle sequencing (10 marks)
A SOC analyst receives an executive request: "Are we at risk from the ransomware group currently targeting our industry?" Arrange the following into the correct order of the Threat Intelligence Lifecycle, and name each phase:

(i) Analysts correlate collected IOCs with internal logs.
(ii) A report is sent to the CISO.
(iii) The request itself is logged as a requirement.
(iv) OSINT and threat feeds are pulled for the group's known TTPs.
(v) The CISO's follow-up questions shape the next collection cycle.

ANSWERS

1A.CIA Triad — Scenario Identification

The CIA Triad is a fundamental model in cybersecurity used to protect information and information systems. CIA stands for Confidentiality, Integrity, and Availability. These three principles help organizations maintain data security, accuracy, and accessibility

1.Principles of the CIA Triad.

1. Confidentiality

Confidentiality ensures that sensitive information is accessible only to authorized users. Encryption, access controls, and authentication help maintain confidentiality.

Example: Preventing unauthorized users from viewing customer payment information.

2. Integrity

Integrity ensures that information remains accurate, complete, and protected against unauthorized modification or deletion.

Example: Ensuring that product prices in an online store cannot be changed by unauthorized users.

3. Availability

Availability ensures that authorized users can access systems, services, and information whenever required.

Example: Keeping an e-commerce website operational during a cyberattack.

2. Analysis of the given scenario

In this scenario, an attacker gains write access to the product database and silently changes product prices. The website remains online, and customers can continue using the service.

- Integrity — Violated: Product prices are changed without authorization. Therefore, the database no longer contains accurate and trustworthy information.
- Confidentiality — Not established as violated: The scenario does not mention that the attacker accessed or disclosed confidential information.
- Availability — Not violated: The website remains fully operational, with no downtime.

3. Measures to prevent this attack

1. Implement role-based access control (RBAC) to restrict database write permissions.
2. Use multi-factor authentication (MFA) for privileged accounts.
3. Maintain database audit logs to identify unauthorized modifications.
4. Apply database integrity checks and alerts for unusual price changes.
5. Maintain secure backups to restore correct product information.

Conclusion: The primary CIA Triad principle violated is Integrity, because an attacker has modified product prices without authorization. Availability remains intact, and the scenario provides insufficient evidence to conclude that confidentiality was compromised.

2A.Risk Quantification — Annualized Loss Expectancy

Risk quantification helps organizations estimate the financial losses caused by cybersecurity incidents. Two important measurements are Single Loss Expectancy (SLE) and Annualized Loss Expectancy (ALE).

Given:

Asset Value (AV) = $50,000

Exposure Factor (EF) = 40% = 0.40

Annualized Rate of Occurrence (ARO) = 2 times per year

Step 1: Calculate Single Loss Expectancy (SLE)

SLE is the estimated financial loss resulting from a single security incident.

Formula:

SLE = Asset Value × Exposure Factor

Substituting the values:

SLE = $50,000 × 0.40

SLE = $20,000

Therefore, SLE = $20,000 per incident.

Step 2: Calculate Annualized Loss Expectancy (ALE)

ALE is the estimated financial loss expected over one year.

Formula:

ALE = SLE × ARO

Substituting the values:

ALE = $20,000 × 2

ALE = $40,000 per year

Therefore, ALE = $40,000 per year.

Conclusion: The expected loss from one breach is $20,000, and the expected annual loss is $40,000. These values help the company estimate its financial risk and decide how much to invest in security measures.

3A. Brute-Force Attack Time Estimation

A brute-force attack is a password-cracking method in which an attacker systematically tries different password combinations until the correct password is found. The time required depends on password length, character set size, and cracking speed.

Given:

Password length = 8 characters

Character set size = 62

Cracking speed = 1 billion passwords per second

1 billion = 10^9

Step 1: Calculate the keyspace

The keyspace represents the total number of possible password combinations.

Formula:

Keyspace = N^L

Where \(N\) is the character set size and \(L\) is the password length.

Keyspace = 62^8

Keyspace = 218,340,105,584,896

Therefore, Keyspace = 218,340,105,584,896 combinations.

Step 2: Calculate the worst-case time in seconds

Formula:

Time = Keyspace ÷ Cracking speed

Time = 218,340,105,584,896 ÷ 1,000,000,000

Time = 218,340.1056 seconds

Step 3: Convert seconds into hours

Since 1 hour = 3,600 seconds:

Time in hours = 218,340.1056 ÷ 3,600

Time = 60.65 hours approximately.

Therefore, the worst-case cracking time is approximately 60.65 hours, or about 2 days, 12 hours, and 39 minutes.

Conclusion: An eight-character password using 62 possible characters has a keyspace of approximately 218.34 trillion combinations. At a cracking speed of one billion attempts per second, exhausting the entire keyspace would take approximately 60.65 hours under the given assumptions. Longer, randomly generated passwords provide substantially greater resistance to brute-force attacks.

Q4. Risk Prioritization Matrix

Risk prioritization is the process of ranking cybersecurity threats according to their likelihood of occurring and the impact they may cause. It helps organizations determine which threats require immediate attention.

Formula:

Risk Score = Likelihood × Impact

The likelihood and impact ratings range from 1 to 5.

Step 1: Calculate the risk scores

(a) Ransomware — Likelihood = 4, Impact = 5

Risk Score = 4 × 5 = 20

(b) Phishing — Likelihood = 5, Impact = 3

Risk Score = 5 × 3 = 15

(c) Insider data theft — Likelihood = 2, Impact = 5

Risk Score = 2 × 5 = 10

(d) DDoS — Likelihood = 3, Impact = 3

Risk Score = 3 × 3 = 9

(e) Unpatched server exploit — Likelihood = 4, Impact = 4

Risk Score = 4 × 4 = 16

Step 2: Rank the threats by priority

Rank	Threat	Likelihood	Impact	Risk Score
1	Ransomware	4	5	20
2	Unpatched server exploit	4	4	16
3	Phishing	5	3	15
4	Insider data theft	2	5	10
5	DDoS	3	3	9

Explanation:

1. Ransomware receives the highest priority because it has the highest risk score and can cause serious data loss and business disruption.
2. The unpatched server exploit ranks second because attackers may exploit software vulnerabilities to gain unauthorized access.
3. Phishing ranks third because it is highly likely to occur and can result in stolen credentials or malware infections.
4. Insider data theft ranks fourth because its likelihood is lower, although its potential impact is high.
5. DDoS ranks fifth because its calculated risk score is the lowest among the five threats.

Conclusion: The organization should prioritize ransomware first, followed by unpatched server exploits, phishing, insider data theft, and DDoS. Actual remediation decisions should also consider active exploitation, asset criticality, and available security patches.

5A. Passive vs. Active Threat Classification

Cybersecurity threats can be classified into passive and active threats based on whether the attacker only observes information or actively manipulates a system or communication.

A passive threat involves monitoring or collecting information without directly changing data or disrupting system operations. An active threat involves modifying information, injecting false data, redirecting communications, or disrupting services.

(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.

Classification: Passive threat

CIA principle: Confidentiality

Explanation: The attacker captures network traffic without modifying it. If the traffic contains passwords or sensitive information, confidentiality is compromised.

(b) An attacker performing ARP spoofing to redirect traffic.

Classification: Active threat

CIA principle: Primarily Integrity

Explanation: The attacker sends forged ARP messages to associate an incorrect MAC address with an IP address. This redirects network traffic and may enable interception or modification of communications. Confidentiality and availability may also be affected.

(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Classification: Passive threat, as described

CIA principle: Confidentiality

Explanation: The attacker gathers information about the network, its devices, and possible targets without modifying data or disrupting operations. However, reconnaissance involving active probing or scanning would be classified as active.

Conclusion: Scenario (a) is a passive threat affecting confidentiality, scenario (b) is an active threat primarily affecting integrity, and scenario (c) is a passive threat affecting confidentiality as described.

6A. Threat Intelligence Lifecycle Sequencing

The Threat Intelligence Lifecycle is a structured process that converts raw threat information into useful intelligence for security decisions. It helps organizations identify threats, analyze evidence, communicate findings, and improve future investigations.

The main phases are Planning and Direction, Collection, Processing, Analysis and Production, Dissemination, and Feedback. Some frameworks combine Processing with Analysis and Production.

Step 1: Planning and Direction — (iii)

The executive request is logged as an intelligence requirement.

Explanation: The SOC identifies the question that must be answered: Is the organization at risk from the ransomware group currently targeting its industry? The team defines the scope and information requirements before collecting data.

Step 2: Collection — (iv)

OSINT and threat feeds are collected to identify the ransomware group's known tactics, techniques, and procedures (TTPs).

Explanation: Analysts gather information from threat intelligence feeds, security advisories, public reports, and other reliable sources to understand the group's activities.

Step 3: Processing, Analysis and Production — (i)

Analysts correlate collected indicators of compromise (IOCs) with internal logs.

Explanation: The team processes and validates the collected information, compares the indicators with internal security logs, and determines whether the organization shows evidence of exposure or suspicious activity.

Step 4: Dissemination — (ii)

The intelligence report is sent to the Chief Information Security Officer (CISO).

Explanation: The report communicates the findings, potential risks, confidence level, and recommended security actions to the decision-maker.

Step 5: Feedback — (v)

The CISO's follow-up questions shape the next collection cycle.

Explanation: The SOC uses feedback to identify missing information, refine intelligence requirements, and improve future investigations.

Correct sequence:

(iii) → (iv) → (i) → (ii) → (v)

Conclusion: The correct sequence is Planning and Direction, Collection, Processing and Analysis, Dissemination, and Feedback. This lifecycle ensures that threat intelligence meets organizational requirements and supports effective cybersecurity decisions.